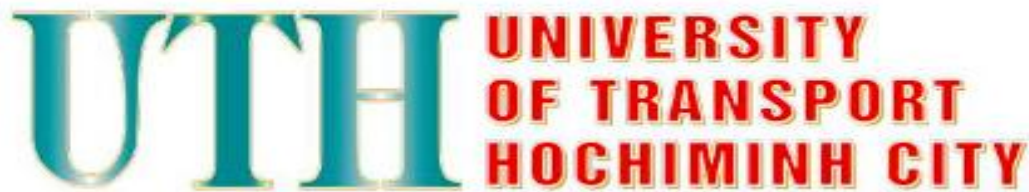


BỘ XÂY DỰNG
TRƯỜNG ĐẠI HỌC GIAO THÔNG VẬN TẢI TP.HCM
VIỆN ĐÀO TẠO CHẤT LƯỢNG CAO



BÁO CÁO
ĐẶC TẢ YÊU CẦU PHẦN MỀM (SRS)

Tên đề tài:

HỆ THỐNG THƯƠNG MẠI ĐIỆN TỬ TECHVIE

Mã dự án: TECHVIE-EC-2026

Phiên bản: 1.0.0 (Final Production Spec)

Ngày phát hành: 26/07/2026

Thực hiện bởi: Nhóm 5

Danh sách thành viên	MSSV
Trần Trung Nam	087205007981
Trần Xuân Phát	040205008154
Nguyễn Hữu Phương	077205000760
Trương Quang Huy	079205013084

CHƯƠNG 1: GIỚI THIỆU TỔNG QUAN (INTRODUCTION)

1.1. Mục đích tài liệu

Tài liệu Đặc tả Yêu cầu Phần mềm (Software Requirements Specification – SRS) này mô tả các yêu cầu nghiệp vụ, yêu cầu chức năng, yêu cầu phi chức năng, yêu cầu giao diện, các ràng buộc và giả định của hệ thống Website Thương mại Điện tử Phụ kiện Công nghệ TechVie. Tài liệu là cơ sở để phân tích, thiết kế, phát triển, kiểm thử và nghiệm thu hệ thống.

Tài liệu phục vụ làm căn cứ chính thức cho:

- **Đội ngũ Phát triển Phần mềm (Developers):** Hiểu và triển khai các chức năng theo yêu cầu đã được đặc tả.
- **Đội ngũ Quản lý Dự án và Kiểm thử (Project Managers / QA):** Theo dõi phạm vi dự án, xây dựng kế hoạch kiểm thử và nghiệm thu hệ thống.
- **Khách hàng / Ban Quản trị:** Hiểu phạm vi chức năng, các yêu cầu của hệ thống và làm căn cứ đánh giá mức độ đáp ứng của sản phẩm.

1.2. Phạm vi hệ thống

Hệ thống TechVie là nền tảng thương mại điện tử (Business-to-Consumer – B2C) chuyên cung cấp các phụ kiện công nghệ và các sản phẩm tùy biến theo nhu cầu khách hàng. Hệ thống hỗ trợ người dùng trong quá trình tìm kiếm, lựa chọn, mua sắm và quản lý đơn hàng trực tuyến, đồng thời cung cấp công cụ quản trị phục vụ việc vận hành và quản lý toàn bộ hoạt động kinh doanh. Phạm vi của hệ thống bao gồm 3 phân hệ chính:

- **Phân hệ Khách hàng (Storefront - B2C):** Cho phép khách hàng xem và tìm kiếm sản phẩm, lọc sản phẩm theo nhiều tiêu chí, quản lý giỏ hàng, đặt hàng trực tuyến, áp dụng mã giảm giá, lựa chọn phương thức thanh toán, quản lý thông tin cá nhân, theo dõi trạng thái đơn hàng, đánh giá các sản phẩm đã mua và đăng ký nhận thông tin khuyến mãi.
- **Phân hệ Quản trị (Admin Dashboard - Operations):** Cho phép quản trị viên quản lý sản phẩm, danh mục, tồn kho, đơn hàng, mã giảm giá, đánh giá của khách hàng, thông tin người dùng, thống kê hoạt động kinh doanh và xử lý các yêu cầu liên hệ từ khách hàng.
- **Phân hệ Tích hợp Máy chủ & Hạ tầng Cloud (Backend & Cloud Services):** Cung cấp các chức năng xử lý nghiệp vụ, quản lý dữ liệu, xác

thực người dùng, lưu trữ hình ảnh, gửi thư điện tử và tích hợp với các dịch vụ bên ngoài (thanh toán, OAuth Google, Nodemailer SMTP).

1.3. Định nghĩa và Thuật ngữ viết tắt

Ký hiệu / Thuật ngữ	Chữ viết đầy đủ	Giải thích nghĩa
API	Application Programming Interface	Giao diện lập trình ứng dụng giao tiếp giữa Client và Server
B2C	Business-to-Consumer	Mô hình kinh doanh giữa doanh nghiệp trực tiếp tới người tiêu dùng
COD	Cash On Delivery	Phương thức thanh toán bằng tiền mặt khi nhận hàng
IPN	Instant Payment Notification	Thông báo thanh toán tức thì từ cổng thanh toán / ngân hàng
JWT	JSON Web Token	Token dạng JSON được ký số, dùng để xác thực người dùng và truyền thông tin định danh, vai trò trong phiên đăng nhập.
RBAC	Role-Based Access Control	Cơ chế kiểm soát truy cập dựa trên vai trò người dùng (User, Employee, Admin).
SRS	Software Requirements Specification	Tài liệu đặc tả yêu cầu phần mềm chuẩn IEEE
VIP Status	Premium Member Status	Trạng thái thành viên thân thiết nhận ưu đãi và bảo vệ đặc quyền

Ký hiệu / Thuật ngữ	Chữ viết đầy đủ	Giải thích nghĩa
Soft Delete	Logical Deletion	Cơ chế xóa ảo (đánh dấu isDeleted: true) để bảo toàn dữ liệu lịch sử

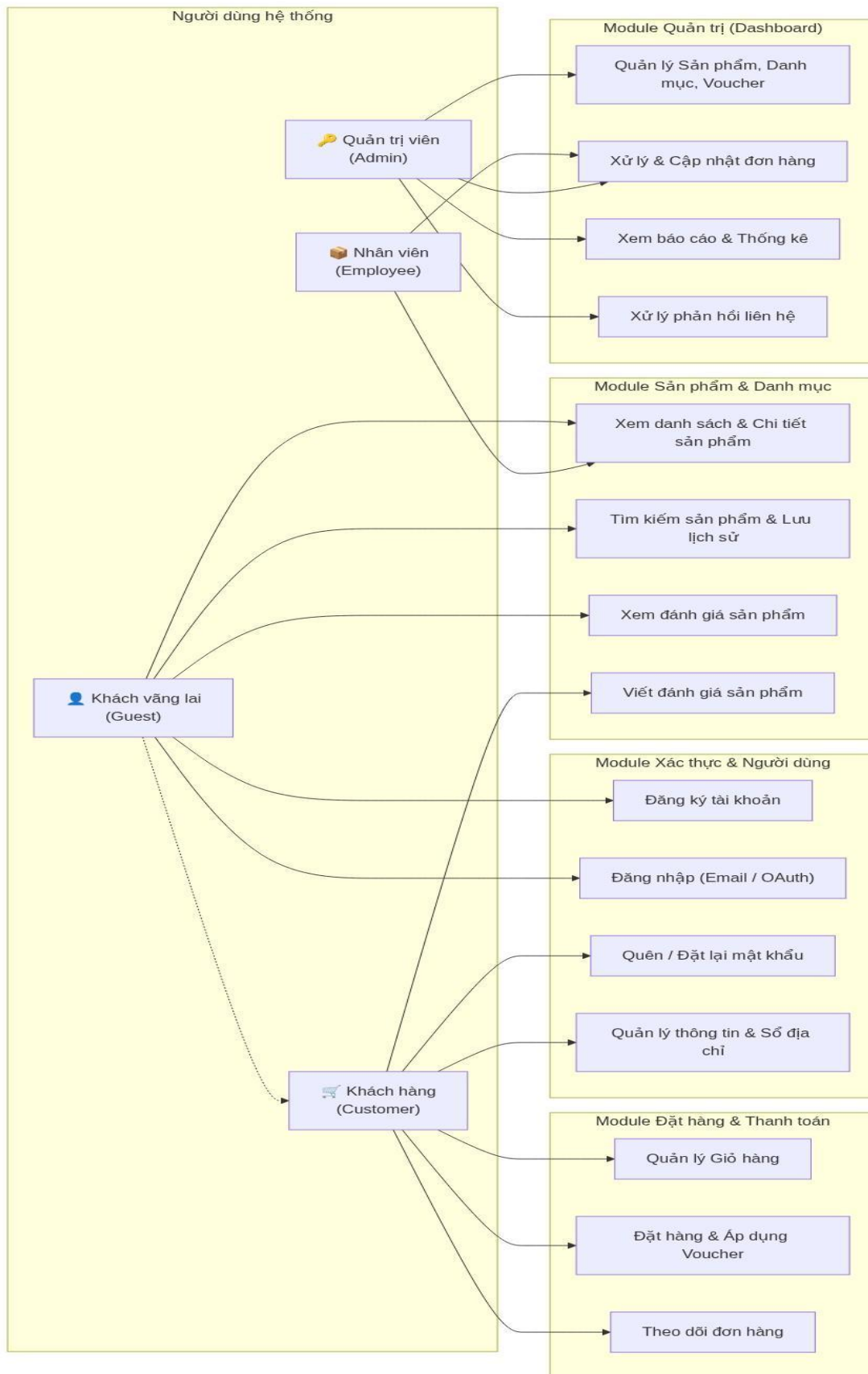
1.4. Tài liệu tham khảo

- (1) IEEE Std 830 - 1998: IEEE Recommended Practice for Software Requirements Specifications.
- (2) Tiêu chuẩn Quốc gia TCVN 11814:2017 về Quy trình Phát triển Phần mềm.
- (3) Bộ Luật Thương mại Điện tử & Nghị định 52/2013/NĐ-CP, Nghị định 85/2021/NĐ-CP của Chính phủ về Quản lý hoạt động TMĐT.
- (4) Báo cáo Học phần Thương mại Điện tử TechVie - Nhóm 5 (ĐH GTVT TP.HCM, Tháng 7/2026).

CHƯƠNG 2: MÔ TẢ TỔNG QUAN HỆ THỐNG (OVERALL DESCRIPTION)

2.1. Kiến trúc tổng thể hệ thống (System Architecture)

Hệ thống TechVie được thiết kế theo kiến trúc Phân lớp Hiện đại (Decoupled Client-Server Architecture). Hệ thống TechVie được xây dựng theo kiến trúc Client–Server tách biệt giữa Frontend và Backend. Frontend chịu trách nhiệm hiển thị giao diện và xử lý tương tác với người dùng, trong khi Backend cung cấp các RESTful API để xử lý nghiệp vụ, xác thực, phân quyền và truy xuất dữ liệu. Dữ liệu của hệ thống được lưu trữ trên MongoDB thông qua Mongoose ODM. Backend đồng thời tích hợp các dịch vụ bên ngoài như Cloudinary, Google OAuth 2.0, Nodemailer SMTP và các dịch vụ thanh toán trực tuyến.



Hình 1. Kiến trúc tổng thể hệ thống TechVie

2.2. Phân loại tác nhân người dùng (User Classes & Actors)

Hệ thống phục vụ 4 nhóm tác nhân chính:

(1) Khách vắng lai (Guest / Anonymous User):

- Truy cập trang chủ, xem danh sách sản phẩm, chi tiết sản phẩm, bài viết tin tức và các chính sách của thương hiệu.
- Tìm kiếm và lọc sản phẩm theo các tiêu chí được hệ thống hỗ trợ; hệ thống có thể ghi nhận lịch sử tìm kiếm theo địa chỉ IP.
- Thêm sản phẩm vào giỏ hàng và quản lý giỏ hàng trên thiết bị người dùng.
- Thực hiện đặt hàng dưới hình thức Guest Checkout mà không bắt buộc đăng nhập tài khoản.
- Đăng ký tài khoản mới, đăng nhập bằng tài khoản TechVie hoặc Google.
- Gửi yêu cầu liên hệ và đăng ký nhận bản tin Newsletter.

(2) Khách hàng đã đăng ký (Registered Customer - Role: user):

- Thực hiện toàn bộ các chức năng của Khách vắng lai.
- Đặt hàng trực tuyến và sử dụng thông tin cá nhân đã lưu để hỗ trợ quá trình Checkout.
- Quản lý hồ sơ cá nhân, số điện thoại, địa chỉ và thay đổi mật khẩu.
- Xác thực địa chỉ email thông qua liên kết được gửi qua hệ thống email.
- Theo dõi lịch sử và trạng thái các đơn hàng cá nhân.
- Tra cứu danh sách thiết bị/sản phẩm đã mua và thông tin bảo hành tương ứng.
- Gửi đánh giá và nhận xét đối với sản phẩm đủ điều kiện Verified Purchase.
- Được quản lý trạng thái thành viên VIP thông qua thuộc tính vipStatus.

(3) Nhân viên vận hành (Employee - Role: employee):

- Đăng nhập vào hệ thống bằng tài khoản nhân viên được cấp quyền.
- Xem danh sách sản phẩm và thông tin cần thiết phục vụ quá trình xử lý đơn hàng.
- Xem và xử lý các đơn hàng được phân công.
- Cập nhật trạng thái xử lý và giao hàng của đơn hàng theo quyền được cấp.
- Xem các yêu cầu liên hệ của khách hàng và hỗ trợ xử lý phản hồi.

- Không được phép thay đổi quyền người dùng, tạo tài khoản quản trị viên hoặc thực hiện các chức năng quản trị cấp cao.

(4) Quản trị viên Hệ thống (System Administrator - Role: admin):

- Đăng nhập quyền Admin bảo mật cao.
- Truy cập Bảng điều khiển (Admin Dashboard) xem tổng quan doanh thu, số lượng đơn hàng, người dùng.
- Quản lý Sản phẩm (CRUD, upload ảnh Cloudinary, khôi phục soft delete).
- Quản lý Danh mục sản phẩm (CRUD & Tự động seed danh mục mặc định).
- Quản lý Đơn hàng: Cập nhật trạng thái xử lý (processing, shipping, success, cancelled) và trạng thái thanh toán (pending, paid, failed, cancelled).
- Quản lý Voucher khuyến mãi: Tạo mã, thiết lập giá trị giảm, kích hoạt/vô hiệu hóa.
- Quản lý Đánh giá: Phản hồi đánh giá của khách hàng, ẩn/hiện đánh giá vi phạm, xóa/khôi phục đánh giá.
- Quản lý Người dùng: Nâng/hạ quyền Admin, nâng cấp trạng thái VIP, Khóa/Mở khóa tài khoản, Xóa/Khôi phục tài khoản.
- Quản lý Hòm thư Liên hệ: Xem ý kiến đóng góp và gửi email trả lời trực tiếp qua hệ thống SMTP.

2.3. Môi trường vận hành và Công nghệ sử dụng

2.3.1. Backend Environment

Hệ thống sử dụng kiến trúc RESTful API chạy trên nền tảng Node.js với framework Express.js để xử lý các yêu cầu từ phía người dùng. Dữ liệu được lưu trữ trên MongoDB và quản lý thông qua Mongoose ODM. Hệ thống sử dụng JSON Web Token (JWT) để xác thực và phân quyền người dùng, kết hợp với bcryptjs để băm mật khẩu. Hệ thống cũng hỗ trợ xác thực bằng Google OAuth 2.0, lưu trữ hình ảnh thông qua Cloudinary và gửi email thông qua Nodemailer SMTP phục vụ chức năng xác thực tài khoản, khôi phục mật khẩu và phản hồi liên hệ.

2.3.2. Frontend Environment

Giao diện người dùng được phát triển theo mô hình Single Page Application (SPA) sử dụng React và TypeScript, được xây dựng với Vite và Tailwind CSS. Hệ thống áp dụng Responsive Web Design nhằm hỗ trợ nhiều kích thước màn hình khác nhau. Các thành phần chuyển động, biểu tượng và thông báo giao diện được sử dụng nhằm nâng cao trải nghiệm người dùng và hỗ trợ các chức năng quản trị.

2.3.3. External Services

Hệ thống tích hợp các dịch vụ bên ngoài bao gồm: - Dịch vụ lưu trữ hình ảnh (Cloudinary API). - Dịch vụ gửi email (Nodemailer SMTP). - Dịch vụ xác thực Google OAuth 2.0. - Cổng thanh toán trực tuyến ở môi trường Sandbox/Demo (SePay IPN / MoMo / ZaloPay / VNPAY).

2.4. Ràng buộc thiết kế và triển khai

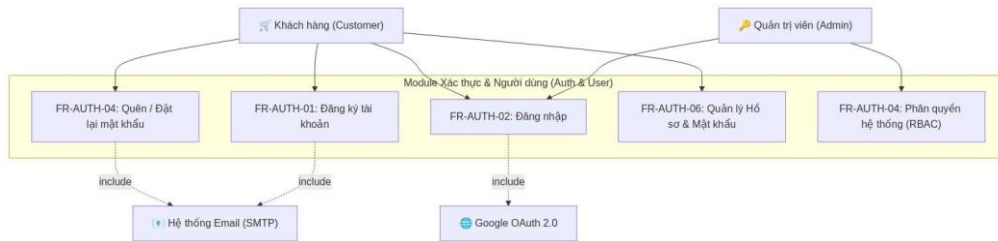
- Hệ thống sử dụng mô hình kiến trúc Client–Server, trong đó Frontend và Backend giao tiếp thông qua RESTful API.
- Mật khẩu người dùng phải được băm bằng thuật toán phù hợp trước khi lưu trữ. Các chức năng yêu cầu quyền hạn phải thực hiện xác thực bằng JWT và kiểm tra vai trò người dùng trước khi cho phép truy cập.
- Dữ liệu giao dịch phải được bảo đảm tính toàn vẹn và nhất quán trong quá trình xử lý đơn hàng.
- Hệ thống phải hỗ trợ hoạt động trên các trình duyệt web hiện đại và giao diện phải đáp ứng trên thiết bị máy tính, máy tính bảng và điện thoại.
- Các dịch vụ bên ngoài như lưu trữ hình ảnh, gửi email và thanh toán được sử dụng thông qua các API do nhà cung cấp cung cấp.

2.5. Giả định và Phụ thuộc

- Máy chủ ứng dụng và cơ sở dữ liệu luôn sẵn sàng để tiếp nhận và xử lý yêu cầu.
- Dịch vụ lưu trữ hình ảnh hoạt động ổn định để cung cấp hình ảnh sản phẩm và các tài nguyên đa phương tiện.
- Dịch vụ gửi email luôn khả dụng để phục vụ chức năng xác thực tài khoản và khôi phục mật khẩu.
- Các dịch vụ xác thực và thanh toán của bên thứ ba phản hồi đúng theo giao thức và định dạng dữ liệu đã công bố.
- Người dùng sử dụng trình duyệt web hiện đại có hỗ trợ JavaScript và kết nối Internet ổn định.

CHƯƠNG 3: YÊU CẦU CHỨC NĂNG CHI TIẾT (DETAILED FUNCTIONAL REQUIREMENTS)

3.1. Phân hệ Xác thực & Quản lý Tài khoản (Auth & User Management)



Hình 2. Sơ đồ chức năng phân hệ Xác thực và Người dùng

3.1.1. FR-AUTH-01: Đăng ký Tài khoản (User Registration)

- Mô tả: Cho phép người dùng tạo tài khoản mới bằng Email và Mật khẩu.
- Luồng xử lý:
 - Người dùng nhập username, email, password, phone (tùy chọn).
 - Hệ thống kiểm tra định dạng dữ liệu, tính duy nhất của email và username trong cơ sở dữ liệu. Các tài khoản đã xóa mềm (isDeleted: true) không được xem là tài khoản đang hoạt động.
 - Mật khẩu được băm (hash) bằng bcryptjs với salt round = 10 trước khi lưu vào cơ sở dữ liệu.
 - Hệ thống tạo tài khoản với isEmailVerified: false. Khi người dùng yêu cầu xác thực email, hệ thống sinh emailVerificationToken có thời hạn 24 giờ và gửi liên kết xác thực tới địa chỉ email đã đăng ký.
 - Sau khi đăng ký thành công, hệ thống trả về thông tin tài khoản và JWT Token chứa thông tin định danh (id, email, role) để duy trì phiên đăng nhập. Token có thời hạn 24 giờ.

3.1.2. FR-AUTH-02: Đăng nhập Hệ thống (User Login)

- Mô tả: Cho phép người dùng đăng nhập bằng Email hoặc Username kết hợp với Mật khẩu.
- Ràng buộc: Tài khoản có status: "blocked" hoặc isDeleted: true không được phép đăng nhập. Tài khoản được tạo bằng Google OAuth phải sử dụng phương thức đăng nhập Google tương ứng.
- Kết quả: Sau khi xác thực thành công, hệ thống trả về JWT Token chứa id, email, role và thông tin cơ bản của người dùng.

3.1.3. FR-AUTH-03: Đăng nhập bằng Google (Google OAuth 2.0 Integration)

- Mô tả: Cho phép người dùng đăng nhập hoặc đăng ký nhanh bằng tài khoản Google.
- Luồng xử lý:
 - Endpoint GET /api/auth/google tạo URL điều hướng tới Google Consent Screen và sinh giá trị state để bảo vệ quá trình OAuth.
 - Sau khi người dùng chấp thuận, Google trả authorization code và state về GET /api/auth/google/callback.
 - Backend kiểm tra tính hợp lệ của state, trao đổi authorization code để lấy thông tin người dùng Google gồm google_id, email, name, avatar.
 - Nếu tài khoản tương ứng đang ở trạng thái blocked, hệ thống từ chối đăng nhập.
 - Nếu email đã tồn tại, hệ thống liên kết google_id, cập nhật auth_provider: "google" và isEmailVerified: true. Nếu chưa tồn tại, hệ thống tạo tài khoản mới với role: "user", vipStatus: "Normal", status: "active" và isEmailVerified: true.
 - Sau khi xác thực thành công, hệ thống tạo JWT Token có thời hạn 24 giờ và điều hướng người dùng trở về Frontend.

3.1.4. FR-AUTH-04: Quên Mật khẩu & Đặt lại Mật khẩu (Forgot & Reset Password)

- Mô tả: Cho phép người dùng sử dụng tài khoản xác thực bằng email/mật khẩu khôi phục mật khẩu thông qua email.
- Luồng xử lý:
 - Người dùng gửi email tới POST /api/auth/forgot-password.
 - Nếu tài khoản được tạo bằng Google OAuth, hệ thống yêu cầu người dùng đăng nhập lại bằng Google và không thực hiện đặt lại mật khẩu.
 - Backend tạo token ngẫu nhiên 32 byte, biểu diễn dưới dạng chuỗi hex 64 ký tự. Token gốc được gửi cho người dùng, còn bản băm SHA-256 của token được lưu vào trường resetPasswordToken.
 - Trường resetPasswordExpire được thiết lập với thời hạn 15 phút. Hệ thống áp dụng thời gian chờ tối thiểu 60 giây giữa các yêu cầu gửi lại email nhằm hạn chế spam.
 - Hệ thống gửi email chứa đường dẫn đặt lại mật khẩu thông qua Nodemailer SMTP.

- Người dùng mở liên kết và gửi mật khẩu mới tới POST /api/auth/reset-password/:token.
- Backend băm token nhận được bằng SHA-256 để đối chiếu với resetPasswordToken và kiểm tra thời hạn sử dụng.
- Mật khẩu mới phải có tối thiểu 6 ký tự và được băm bằng bcryptjs trước khi lưu.
- Sau khi đặt lại mật khẩu thành công, hệ thống xóa resetPasswordToken và resetPasswordExpire.

3.1.5. FR-AUTH-05: Xác thực Email (Email Verification)

- Mô tả: Xác minh quyền sở hữu địa chỉ email của người dùng đã đăng nhập.
- Luồng xử lý:
 - Người dùng đã đăng nhập yêu cầu gửi email xác thực thông qua POST /api/auth/send-verification-email.
 - Nếu isEmailVerified: true, hệ thống không gửi lại email xác thực.
 - Backend tạo token xác thực ngẫu nhiên, băm token bằng SHA-256 trước khi lưu vào emailVerificationToken.
 - emailVerificationExpire có thời hạn 24 giờ; hệ thống giới hạn việc yêu cầu gửi lại email tối thiểu 60 giây/lần.
 - Token gốc được gửi tới email người dùng dưới dạng liên kết xác thực.
 - Người dùng truy cập GET /api/auth/verify-email?token=.... Backend băm token nhận được và đối chiếu với token lưu trong cơ sở dữ liệu.
 - Nếu token hợp lệ và chưa hết hạn, hệ thống cập nhật isEmailVerified: true, đồng thời xóa emailVerificationToken và emailVerificationExpire.
 - Sau khi xác thực thành công, người dùng được chuyển về trang tài khoản trên Frontend.
- Kết quả: Cập nhật isEmailVerified: true.

3.1.6. FR-AUTH-06: Quản lý Hồ sơ & Đổi Mật khẩu (Profile & Password Change)

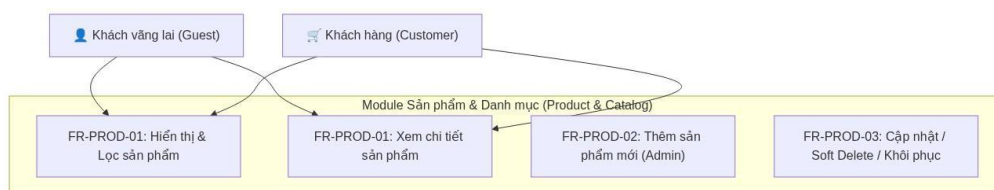
- Mô tả: Cho phép người dùng đã đăng nhập xem và cập nhật thông tin cá nhân, đồng thời thay đổi mật khẩu tài khoản.
- Chức năng:
 - GET /api/auth/profile: Lấy thông tin hồ sơ của tài khoản hiện tại.

- PUT /api/auth/profile: Cập nhật tên hiển thị (username), số điện thoại (phone) và địa chỉ (address).
- POST /api/auth/change-password: Cho phép người dùng thay đổi mật khẩu bằng cách cung cấp currentPassword và newPassword.
- Ràng buộc: Mật khẩu hiện tại phải được xác minh chính xác trước khi đổi. Mật khẩu mới được băm bằng bcryptjs trước khi lưu vào cơ sở dữ liệu.
- Quyền truy cập: Chỉ người dùng đã được xác thực bằng JWT mới được sử dụng các chức năng trên.

3.1.7. FR-AUTH-07: Tra cứu Thiết bị đã mua & Thông tin Bảo hành

- Mô tả: Cho phép khách hàng đã đăng nhập xem danh sách sản phẩm/thiết bị thuộc các đơn hàng đã giao thành công.
- Endpoint: GET /api/auth/my-devices.
- Điều kiện: Chỉ lấy sản phẩm thuộc các đơn hàng có status_type: "success" của email người dùng hiện tại.
- Thông tin trả về: Mã sản phẩm, tên sản phẩm, giá mua, ngày mua, ngày hết hạn bảo hành, hình ảnh và thông số kỹ thuật (specs).
- Bảo hành: Hệ thống xác định thời hạn bảo hành mặc định 2 năm kể từ ngày mua đối với chức năng tra cứu hiện tại.
- Quyền truy cập: Logged In.

3.2. Phân hệ Danh mục & Quản lý Sản phẩm (Catalog & Product Management)



Hình 3. Sơ đồ chức năng phân hệ Sản phẩm và Danh mục

3.2.1. FR-PROD-01: Truy vấn Danh sách Sản phẩm (Get Products & Filtering)

- Mô tả: Cung cấp danh sách sản phẩm phục vụ hiển thị trên trang chủ và trang sản phẩm.
- Bộ lọc hỗ trợ:

- Theo Danh mục (category): Điện thoại, Laptop, Đồng hồ, Âm thanh, Bàn phím, Combo, Phụ kiện.
- Theo Trạng thái (status): AVAILABLE, OUT_OF_STOCK, DISCONTINUED.
- Theo Huy hiệu (badge): PREMIUM, TRENDY, FLAGSHIP, LIMITED, NORMAL.
- Tìm kiếm theo Từ khóa (search): Tìm kiếm tương đối không phân biệt hoa thường trong name và description.
- Phân trang & Sắp xếp: Sắp xếp theo Giá tăng/giảm, Đánh giá trung bình (averageRating), Mới nhất (created_at).

3.2.2. FR-PROD-02: Thêm mới Sản phẩm (Create Product - Admin Only)

- Mô tả: Cho phép Admin tạo sản phẩm mới và có thể tải hình ảnh đại diện của sản phẩm lên Cloudinary.
- Ràng buộc & Xử lý:
 - Các trường bắt buộc gồm name, price và category.
 - Giá sản phẩm (price) phải lớn hơn hoặc bằng 0; số lượng tồn kho (stock) phải lớn hơn hoặc bằng 0.
 - Hệ thống tự động sinh _id từ tên sản phẩm theo dạng slug. Nếu _id đã tồn tại, hệ thống tự động bổ sung hậu tố để bảo đảm mã sản phẩm duy nhất.
 - Nếu Admin tải tệp ảnh lên, Backend sử dụng Multer tiếp nhận tệp và lưu ảnh trên Cloudinary trong thư mục sản phẩm của TechVie. URL ảnh sau khi tải lên được lưu trong trường image.
 - Trường specs lưu thông số kỹ thuật dưới dạng dữ liệu JSON và colors lưu danh sách màu sắc của sản phẩm.
 - Khi tạo mới, sản phẩm mặc định có status: "AVAILABLE", badge: "NORMAL", stock: 0 nếu chưa khai báo và isDeleted: false.
- Endpoint: POST /api/products.
- Quyền truy cập: Admin.

3.2.3. FR-PROD-03: Cập nhật & Xóa Sản phẩm (Update, Soft Delete & Restore - Admin Only)

- Mô tả: Cho phép Admin cập nhật thông tin, xóa mềm và khôi phục sản phẩm trong hệ thống.
- Cập nhật sản phẩm: Admin có thể cập nhật name, price, stock, category, description, specs, colors, badge và hình ảnh sản phẩm. Nếu tải ảnh mới

lên Cloudinary, hệ thống thực hiện xóa ảnh cũ trước khi lưu URL ảnh mới.

- Soft Delete: Khi xóa sản phẩm, hệ thống cập nhật isDeleted: true và chuyển status sang "DISCONTINUED". Sản phẩm không còn hiển thị đối với khách hàng nhưng dữ liệu vẫn được bảo toàn để phục vụ lịch sử đơn hàng.
- Khôi phục: Khi khôi phục, hệ thống cập nhật isDeleted: false và chuyển status về "AVAILABLE".
- Endpoints:
 - PUT /api/products/:id – Cập nhật sản phẩm.
 - DELETE /api/products/:id – Xóa mềm sản phẩm.
 - PATCH /api/products/:id/restore – Khôi phục sản phẩm.
- Quyền truy cập: Admin.

3.2.4. FR-CAT-01: Truy vấn Danh sách Danh mục

- Mô tả: Cho phép người dùng lấy danh sách các danh mục sản phẩm đang hoạt động trong hệ thống.
- Xử lý: Mặc định hệ thống chỉ trả về các danh mục chưa bị xóa hoặc vô hiệu hóa (isDeleted != true) và sắp xếp theo thời gian tạo tăng dần.
- Endpoint: GET /api/categories.
- Quyền truy cập: Public.

3.2.5. FR-CAT-02: Tạo & Cập nhật Danh mục (Create & Update Category - Admin Only)

- Mô tả: Cho phép Admin tạo danh mục mới hoặc thay đổi tên danh mục hiện có.
- Ràng buộc:
 - Tên danh mục không được để trống.
 - Tên danh mục phải duy nhất và được kiểm tra không phân biệt chữ hoa/chữ thường.
 - Nếu Admin tạo một danh mục có tên trùng với danh mục đã bị xóa mềm trước đó, hệ thống khôi phục danh mục cũ thay vì tạo thêm bản ghi trùng lặp.
- Endpoints:
 - POST /api/categories – Tạo danh mục.
 - PUT /api/categories/:id – Cập nhật danh mục.
- Quyền truy cập: Admin.

3.2.6. FR-CAT-03: Vô hiệu hóa, Khôi phục & Xóa Danh mục (Category Lifecycle - Admin Only)

- Mô tả: Cho phép Admin quản lý vòng đời của danh mục sản phẩm.
- Xóa mềm: DELETE /api/categories/:id đặt isDeleted: true.
- Khôi phục: PATCH /api/categories/:id/restore đặt isDeleted: false.
- Bật/Tắt: PATCH /api/categories/:id/toggle cho phép chuyển đổi nhanh trạng thái hoạt động của danh mục.
- Xóa vĩnh viễn: DELETE /api/categories/:id/permanent xóa hoàn toàn danh mục khỏi cơ sở dữ liệu.
- Ràng buộc hiển thị: Khi một danh mục bị vô hiệu hóa, các sản phẩm thuộc danh mục đó không được hiển thị trong danh sách sản phẩm công khai.
- Quyền truy cập: Admin.

3.3. Phân hệ Tìm kiếm & Phân tích Từ khóa (Search & Analytics)

3.3.1. FR-SRCH-01: Tìm kiếm Sản phẩm Thời gian Thực (Real-time Product Search)

- Mô tả: Cho phép người dùng tìm kiếm nhanh sản phẩm thông qua Search Side Panel trên giao diện.
- Luồng xử lý:
 - Người dùng nhập từ khóa tìm kiếm trên giao diện.
 - Frontend áp dụng cơ chế debounce 300 ms nhằm hạn chế gửi yêu cầu liên tục khi người dùng đang nhập.
 - Frontend gửi yêu cầu GET /api/products?search=<keyword> tới Backend.
 - Backend thực hiện tìm kiếm không phân biệt chữ hoa/chữ thường trên các trường name, description và category.
 - Hệ thống chỉ trả về các sản phẩm phù hợp và không hiển thị sản phẩm đã bị xóa mềm hoặc thuộc danh mục đang bị vô hiệu hóa.
 - Kết quả tìm kiếm được hiển thị trực tiếp trên Search Side Panel; người dùng có thể mở chi tiết sản phẩm hoặc thêm sản phẩm vào giỏ hàng.
- Quyền truy cập: Public.

3.3.2. FR-SRCH-02: Ghi nhận Nhật ký Tìm kiếm (Search Logging)

- Mô tả: Hệ thống ghi nhận từ khóa tìm kiếm nhằm phục vụ chức năng lịch sử tìm kiếm và phân tích từ khóa phổ biến.
- Luồng xử lý:
 - Khi Backend nhận yêu cầu tìm kiếm có tham số search, hệ thống ghi nhận từ khóa vào collection SearchLog.
 - Nếu request có JWT hợp lệ, hệ thống lấy thông tin định danh người dùng từ token và lưu vào trường userId.
 - Nếu người dùng chưa đăng nhập, userId được để null và hệ thống sử dụng địa chỉ IP để nhận diện lịch sử tìm kiếm của khách vãng lai.
 - Thời điểm tìm kiếm được tự động ghi nhận trong trường created_at.
- Dữ liệu SearchLog:
 - **query:** từ khóa tìm kiếm.
 - **userId:** ID hoặc thông tin định danh người dùng nếu đã đăng nhập.
 - **ip:** địa chỉ IP của request.
 - **created_at:** thời điểm thực hiện tìm kiếm.

3.3.3. FR-SRCH-03: Phân tích Từ khóa Phổ biến & Lịch sử Tìm kiếm (Popular & Recent Searches)

- Mô tả: Cung cấp danh sách từ khóa được tìm kiếm phổ biến trong toàn hệ thống và lịch sử tìm kiếm gần đây của từng người dùng hoặc khách vãng lai.
- Từ khóa tìm kiếm phổ biến:
 - Endpoint: GET /api/search/popular.
 - Hệ thống nhóm các bản ghi SearchLog theo từ khóa không phân biệt chữ hoa/chữ thường.
 - Số lần xuất hiện của mỗi từ khóa được thống kê và sắp xếp giảm dần.
 - Hệ thống trả về tối đa 5 từ khóa được tìm kiếm nhiều nhất.
- Lịch sử tìm kiếm gần đây:
 - Endpoint: GET /api/search/history.
 - Nếu người dùng có JWT hợp lệ, lịch sử được truy vấn theo userId.
 - Nếu là khách vãng lai, lịch sử được truy vấn theo địa chỉ IP.
 - Hệ thống lấy các bản ghi mới nhất theo created_at giảm dần, loại bỏ các từ khóa bị trùng không phân biệt chữ hoa/chữ thường và trả về tối đa 5 từ khóa gần nhất không trùng nhau.
- Quyền truy cập: Public; JWT là tùy chọn để xác định lịch sử cá nhân.

3.4. Phân hệ Giỏ hàng & Khuyến mãi (Cart & Voucher System)

3.4.1. FR-CART-01: Quản lý Giỏ hàng Trục tuyến (Client-side Cart Management)

- Mô tả: Cho phép khách vắng lai và khách hàng đã đăng nhập thêm, cập nhật và quản lý các sản phẩm đã chọn trước khi thực hiện Checkout.
- Lưu trữ: Giỏ hàng được lưu tại phía Client trong LocalStorage với khóa `techvie_cart`, giúp duy trì dữ liệu khi người dùng tải lại trang.
- Tính năng:
 - Thêm sản phẩm vào giỏ hàng kèm tùy chọn màu sắc (`selectedColor`).
 - Mỗi mục trong giỏ được phân biệt dựa trên `productId` và `selectedColor`.
 - Nếu thêm lại cùng sản phẩm và cùng màu sắc, hệ thống tăng số lượng (`quantity`) thay vì tạo mục mới.
 - Cho phép tăng hoặc giảm số lượng sản phẩm; nếu số lượng giảm về 0, sản phẩm được tự động xóa khỏi giỏ.
 - Cho phép xóa từng sản phẩm hoặc xóa toàn bộ giỏ hàng.
 - Cho phép thay đổi màu sắc của sản phẩm trực tiếp trong Cart Side Panel. Nếu sản phẩm với màu mới đã tồn tại trong giỏ, hệ thống gộp số lượng của hai mục.
 - Hệ thống tự động tính tổng số lượng sản phẩm và tổng giá trị tạm tính theo công thức $\text{price} \times \text{quantity}$.
 - Phí vận chuyển, Voucher và tổng tiền cuối cùng được tính tại bước Checkout.
- Quyền truy cập: Public; người dùng không bắt buộc phải đăng nhập để sử dụng giỏ hàng.

3.4.2. FR-VOCH-01: Áp dụng Mã Giảm giá (Apply Voucher)

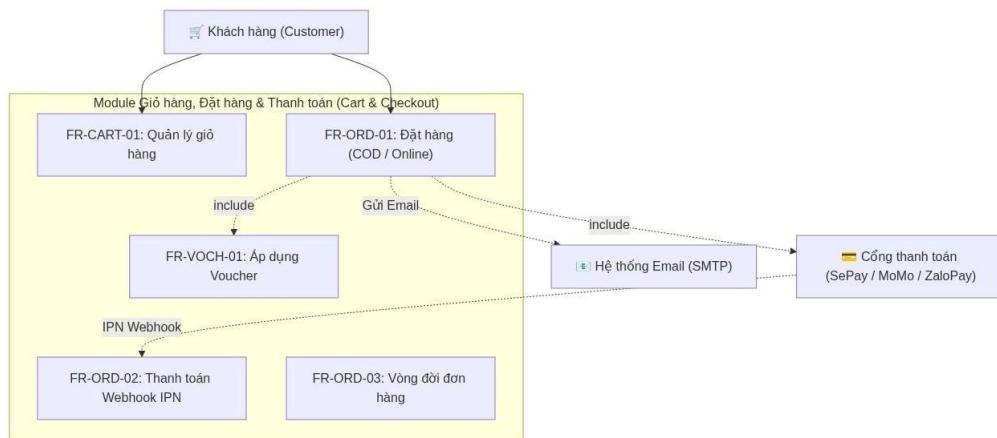
- Mô tả: Cho phép khách hàng nhập mã Voucher tại màn hình Checkout để nhận ưu đãi khi đơn hàng đáp ứng các điều kiện của chương trình.
- Luồng xử lý:
 - Người dùng nhập mã Voucher; hệ thống chuẩn hóa mã thành chữ in hoa trước khi kiểm tra.
 - Hệ thống kiểm tra mã Voucher có tồn tại hay không.
 - Voucher chỉ được áp dụng khi có `isActive: true`.
 - Nếu Voucher có `minOrderVal > 0`, tổng giá trị hàng hóa (`subtotal`) phải lớn hơn hoặc bằng giá trị đơn hàng tối thiểu.
 - Trường `discount` biểu diễn tỷ lệ giảm giá, ví dụ 0.1 tương ứng giảm 10%.

- Số tiền giảm được tính theo công thức: $\text{discountAmount} = \text{subtotal} \times \text{discount}$.
- Tổng tiền cuối cùng được tính theo công thức: $\text{finalTotal} = \text{subtotal} + \text{deliveryFee} - \text{discountAmount}$.
- Nếu mã không tồn tại, đang tạm dừng hoặc đơn hàng chưa đạt giá trị tối thiểu, hệ thống hiển thị thông báo lỗi và không áp dụng giảm giá.
- Quyền truy cập: Guest và User đều có thể áp dụng Voucher khi Checkout.

3.4.3. FR-VOCH-02: Quản lý Mã Giảm giá (Voucher Administration - Admin Only)

- Mô tả: Cho phép Admin tạo, xem, kích hoạt/vô hiệu hóa và xóa các Voucher của hệ thống.
- Cấu trúc Voucher:
 - code: Mã Voucher duy nhất, tự động chuẩn hóa thành chữ in hoa.
 - discount: Tỷ lệ giảm giá.
 - description: Nội dung mô tả chương trình ưu đãi.
 - minOrderVal: Giá trị đơn hàng tối thiểu để được sử dụng Voucher.
 - usedCount: Số lượt Voucher đã được sử dụng, phục vụ thống kê.
 - isActive: Trạng thái hoạt động của Voucher.
 - created_at: Thời điểm tạo Voucher.
- Chức năng:
 - GET /api/vouchers: Lấy danh sách Voucher.
 - POST /api/vouchers: Tạo Voucher mới. Mã Voucher không được trùng với mã đã tồn tại.
 - PUT /api/vouchers/:id/toggle: Chuyển đổi trạng thái isActive giữa kích hoạt và tạm dừng.
 - DELETE /api/vouchers/:id: Xóa Voucher khỏi hệ thống.
 - API Toggle và Delete hỗ trợ xác định Voucher bằng _id hoặc code.
- Quyền quản trị: Các thao tác tạo, thay đổi trạng thái và xóa Voucher chỉ dành cho Admin.

3.5. Phân hệ Đặt hàng & Thanh toán (Checkout, Gateways & Orders)



Hình 4. Sơ đồ quy trình Giỏ hàng, Đặt hàng và Thanh toán

3.5.1. FR-ORD-01: Quy trình Đặt hàng (Checkout Flow)

- Mô tả: Cho phép khách vắng lai và khách hàng đã đăng nhập thực hiện Checkout, cung cấp thông tin giao nhận, lựa chọn phương thức vận chuyển, thanh toán và tạo đơn hàng mới.
- Quyền truy cập: Public. Hệ thống hỗ trợ Guest Checkout, không bắt buộc người mua phải đăng nhập. Với người dùng đã đăng nhập, đơn hàng có thể liên kết với tài khoản thông qua user_id.
- Thông tin giao nhận:
 - full_name: Họ tên người nhận.
 - phone: Số điện thoại liên hệ.
 - email: Email người đặt hàng.
 - address: Địa chỉ nhận hàng.
 - notes: Ghi chú giao hàng (tùy chọn).
- Phương thức vận chuyển (delivery_method):
 - standard: Giao hàng tiêu chuẩn.
 - express: Giao hàng hỏa tốc.
- Phương thức thanh toán (payment_method):
 - cod: Thanh toán khi nhận hàng.
 - card_online: Thanh toán thẻ trực tuyến.
 - bank_transfer: Chuyển khoản ngân hàng qua QR / SePay.
 - momo: Thanh toán qua MoMo Sandbox/Demo.
 - zalopay: Thanh toán qua ZaloPay Sandbox/Demo.
 - vnpay: Thanh toán qua VNPAY Sandbox/Demo.
- Luồng xử lý:

- Người dùng xác nhận các sản phẩm trong giỏ hàng và cung cấp đầy đủ thông tin giao nhận bắt buộc.
- Hệ thống kiểm tra giỏ hàng không được rỗng và xác thực dữ liệu Checkout.
- Hệ thống kiểm tra sản phẩm còn tồn tại, đang được phép kinh doanh và số lượng đặt không vượt quá tồn kho khả dụng.
- Hệ thống tính subtotal, phí vận chuyển (deliveryFee), số tiền giảm giá (discountAmount) và tổng tiền cuối cùng (finalTotal).
- Nếu có Voucher hợp lệ, hệ thống áp dụng mức giảm theo FR-VOCH-01.
- Hệ thống tạo đơn hàng với trạng thái ban đầu status_type: "processing" và payment_status: "pending".
- Số lượng tồn kho của các sản phẩm được cập nhật tương ứng sau khi đơn hàng được tạo thành công.
- Hệ thống trả về thông tin đơn hàng và hướng dẫn/thông tin thanh toán tương ứng với phương thức đã chọn.
- Endpoint: POST /api/checkout.

3.5.2. FR-ORD-02: Tích hợp Thanh toán & IPN Webhook (Payment Gateway Integration)

- Mô tả: Hỗ trợ xử lý và cập nhật trạng thái thanh toán của đơn hàng thông qua các phương thức thanh toán trực tuyến được tích hợp ở môi trường Sandbox/Demo.
- Thanh toán chuyển khoản qua SePay:
 - Khi người dùng chọn bank_transfer, hệ thống cung cấp thông tin thanh toán/QR cùng mã đơn hàng để phục vụ đối soát.
 - Endpoint POST /api/checkout/payment/sepay-ipn tiếp nhận thông báo giao dịch từ SePay.
 - Hệ thống xác định đơn hàng thông qua mã đơn hàng (order_id) có trong thông tin giao dịch.
 - Hệ thống đối chiếu số tiền nhận được với tổng tiền phải thanh toán của đơn hàng.
 - Nếu giao dịch hợp lệ và số tiền khớp, hệ thống cập nhật payment_status: "paid" và lưu thông tin giao dịch như paid_at và transaction_id.
 - Nếu thanh toán không thành công, trạng thái thanh toán được giữ hoặc cập nhật phù hợp (pending, failed, cancelled).

- Giả lập thanh toán phục vụ kiểm thử: Endpoint POST `/api/checkout/payment/sepay-ipn/simulate/:orderId` cho phép Developer/Tester mô phỏng giao dịch SePay trong môi trường kiểm thử.
- Các cổng thanh toán khác: MoMo, ZaloPay, VNPay và thanh toán thẻ trực tuyến được tích hợp theo cơ chế Sandbox/Demo phù hợp với từng nhà cung cấp.

3.5.3. FR-ORD-03: Quản lý Đơn hàng (Order Lifecycle Management)

- Mô tả: Cho phép theo dõi và quản lý đơn hàng từ thời điểm được tạo cho đến khi giao hàng thành công hoặc bị hủy.
- Trạng thái xử lý (status_type):
 - processing: Đơn hàng đang được tiếp nhận và xử lý.
 - shipping: Đơn hàng đã được chuyển sang quá trình giao hàng.
 - success: Đơn hàng đã giao thành công.
 - cancelled: Đơn hàng đã bị hủy.
- Trạng thái thanh toán (payment_status):
 - pending: Chưa thanh toán hoặc đang chờ xác nhận.
 - paid: Đã thanh toán.
 - failed: Thanh toán thất bại.
 - cancelled: Thanh toán/đơn hàng đã bị hủy.
- Quyền truy cập:
 - Khách hàng đã đăng nhập xem lịch sử và trạng thái các đơn hàng cá nhân thông qua GET `/api/orders/user`.
 - Admin xem danh sách toàn bộ đơn hàng thông qua GET `/api/orders`.
 - Admin cập nhật trạng thái xử lý thông qua POST `/api/orders/:id/status`.
 - Admin cập nhật trạng thái thanh toán thông qua POST `/api/orders/:id/payment-status`.
 - Nhân viên (Employee) được phép xem và xử lý các đơn hàng theo phạm vi quyền được hệ thống cấp.
- Ràng buộc dữ liệu: Các đơn hàng đã tạo phải được bảo lưu để phục vụ lịch sử mua hàng, thống kê, đánh giá sản phẩm và tra cứu bảo hành.

3.6. Phân hệ Đánh giá & Nhận xét Sản phẩm (Reviews & Ratings)

3.6.1. FR-REV-01: Gửi Đánh giá Sản phẩm (Submit Product Review)

- Mô tả: Cho phép khách hàng đã đăng nhập gửi đánh giá đối với sản phẩm mà mình đã mua và nhận hàng thành công.

- Ràng buộc Verified Purchase: Người dùng chỉ được đánh giá sản phẩm khi tồn tại ít nhất một đơn hàng của người dùng có chứa product_id tương ứng và đơn hàng có status_type: "success".
- Chống Spam: Mỗi người dùng chỉ được tạo một đánh giá cho mỗi sản phẩm. Hệ thống sử dụng ràng buộc duy nhất trên cặp {product_id, user_id}.
- Nội dung đánh giá:
 - rating: Điểm đánh giá từ 1 đến 5 sao.
 - title: Tiêu đề đánh giá.
 - comment: Nội dung nhận xét.
- Kết quả: Khi đánh giá được tạo thành công, hệ thống đánh dấu verified_purchase: true và liên kết đánh giá với order_id dùng để xác minh giao dịch.
- Endpoint: POST /api/reviews/:productId.
- Quyền truy cập: Logged In – Verified Buyer.

3.6.2. FR-REV-02: Tự động Tính toán Điểm Đánh giá Trung bình (Rating Aggregation)

- Mô tả: Hệ thống tự động cập nhật điểm đánh giá của sản phẩm khi dữ liệu Review thay đổi.
- Luồng xử lý:
 - Khi một đánh giá được tạo, cập nhật, xóa mềm hoặc khôi phục, hệ thống thực hiện tính lại thống kê đánh giá của sản phẩm tương ứng.
 - Chỉ các đánh giá hợp lệ và chưa bị xóa mềm được sử dụng để tính điểm.
 - Hệ thống tính điểm trung bình của trường rating và làm tròn đến 1 chữ số thập phân.
 - Hệ thống đếm tổng số đánh giá hợp lệ.
 - Kết quả được cập nhật vào averageRating và reviewCount của Product.
- Trường hợp không còn đánh giá: averageRating = 0 và reviewCount = 0.

3.6.3. FR-REV-03: Quản trị Đánh giá (Review Moderation - Admin)

- Mô tả: Cho phép Admin kiểm duyệt, phản hồi, ẩn/hiện và quản lý vòng đời các đánh giá của khách hàng.
- Chức năng:
 - Admin xem các đánh giá của sản phẩm và thông tin người đánh giá.

- Admin phản hồi đánh giá thông qua thuộc tính reply, bao gồm nội dung phản hồi, thời điểm phản hồi và thông tin Admin thực hiện.
- Admin có thể ẩn hoặc hiển thị lại đánh giá vi phạm thông qua PATCH /api/reviews/:reviewId/toggle-hide.
- Admin có thể thực hiện Soft Delete đối với đánh giá; đánh giá bị xóa mềm không được hiển thị cho khách hàng.
- Admin có thể khôi phục đánh giá đã bị xóa mềm.
- Sau các thao tác làm thay đổi tập hợp đánh giá hợp lệ, hệ thống cập nhật lại averageRating và reviewCount của sản phẩm theo FR-REV-02.
- Quyền truy cập: Admin.

3.7. Phân hệ Hỗ trợ Khách hàng & Newsletter (Contact & Marketing)

3.7.1. FR-CNT-01: Gửi Thư Liên hệ (Contact Form)

- Mô tả: Cho phép khách vãng lai hoặc khách hàng gửi yêu cầu tư vấn, góp ý hoặc phản hồi tới bộ phận hỗ trợ TechVie.
- Thông tin gửi:
 - name: Họ tên người gửi.
 - email: Địa chỉ email nhận phản hồi.
 - subject: Chủ đề liên hệ.
 - message: Nội dung yêu cầu hoặc góp ý.
- Luồng xử lý:
 - Người dùng nhập thông tin trên Contact Form.
 - Hệ thống yêu cầu tối thiểu name và email không được để trống.
 - Nếu subject không được cung cấp, hệ thống có thể sử dụng chủ đề mặc định.
 - Nếu message không được cung cấp, hệ thống có thể sử dụng nội dung mặc định phù hợp với loại yêu cầu.
 - Thông tin liên hệ được lưu vào collection Contact cùng thời điểm gửi created_at.
 - Sau khi lưu thành công, hệ thống thông báo kết quả cho người dùng.
- Endpoint: POST /api/contacts.
- Quyền truy cập: Public.

3.7.2. FR-CNT-02: Quản lý Thư Liên hệ & Trả lời qua Email (Contact Inbox & SMTP Reply)

- Mô tả: Cho phép người có quyền quản trị xem, xử lý, phản hồi và xóa các yêu cầu liên hệ của khách hàng.
- Chức năng:
 - GET /api/contacts: Lấy danh sách toàn bộ thư liên hệ và sắp xếp theo thời gian gửi mới nhất.
 - POST /api/contacts/:id/reply: Gửi email phản hồi tới địa chỉ email của người gửi thông qua Nodemailer SMTP.
 - Nội dung phản hồi gồm replySubject và replyContent; trong đó replyContent không được để trống.
 - Nếu không cung cấp replySubject, hệ thống tự động tạo tiêu đề dựa trên chủ đề của thư liên hệ ban đầu.
 - DELETE /api/contacts/:id: Xóa thư liên hệ khỏi hệ thống.
 - Nếu không tìm thấy thư liên hệ tương ứng, hệ thống trả về thông báo lỗi.
- Quyền truy cập: Admin. Nhân viên (Employee) có thể được cấp quyền xem và xử lý liên hệ theo ma trận RBAC của hệ thống.

3.7.3. FR-CNT-03: Đăng ký Nhận Bản tin (Newsletter Subscription)

- Mô tả: Cho phép người dùng đăng ký nhận thông tin sản phẩm, chương trình khuyến mãi và thông báo marketing từ TechVie thông qua địa chỉ email.
- Luồng xử lý:
 - Người dùng nhập địa chỉ email tại khu vực Newsletter trên giao diện.
 - Frontend gửi yêu cầu đăng ký tới POST /api/contacts với nội dung được đánh dấu là yêu cầu đăng ký Newsletter.
 - Hệ thống kiểm tra email không được để trống trước khi tiếp nhận yêu cầu.
 - Khi đăng ký thành công, hệ thống trả về thông báo xác nhận cho người dùng.
 - Frontend có thể ghi nhận trạng thái đăng ký trên thiết bị người dùng để tránh hiển thị lại biểu mẫu không cần thiết.
- Quyền truy cập: Public.

3.8. Phân hệ Quản trị & Báo cáo Vận hành (Admin Management & Dashboard)

3.8.1. FR-ADM-01: Bảng Điều khiển Tổng quan (Admin Dashboard Metrics)

- Mô tả: Cung cấp cho Admin cái nhìn tổng quan về tình trạng hoạt động kinh doanh và vận hành của hệ thống TechVie.
- Các chỉ số chính:
 - Doanh thu: Tổng giá trị các đơn hàng đã được xác nhận thanh toán với `payment_status: "paid"`.
 - Đơn hàng: Tổng số đơn hàng và số lượng đơn theo từng trạng thái `processing, shipping, success, cancelled`.
 - Sản phẩm: Tổng số sản phẩm đang kinh doanh, số sản phẩm còn hàng, hết hàng và sản phẩm có tồn kho thấp.
 - Cảnh báo tồn kho: Sản phẩm có `stock <= 5` được đưa vào danh sách cảnh báo sắp hết hàng.
 - Người dùng: Tổng số tài khoản đang hoạt động, số tài khoản bị khóa và số thành viên VIP.
 - Đánh giá: Có thể hiển thị tổng số đánh giá và điểm đánh giá trung bình của sản phẩm phục vụ việc theo dõi chất lượng.
- Quyền truy cập: Admin. Nhân viên (Employee) có thể được cấp quyền xem một số chỉ số vận hành giới hạn theo ma trận RBAC.

3.8.2. FR-ADM-02: Quản lý Thành viên & Phân quyền (User Administration & RBAC)

- Mô tả: Cho phép Admin quản lý tài khoản người dùng, trạng thái hoạt động, cấp độ thành viên và vai trò truy cập trong hệ thống.
- Chức năng:
 - Xem danh sách toàn bộ tài khoản trong hệ thống.
 - Xem thông tin cơ bản của người dùng như `username, email, role, vipStatus, status` và trạng thái xóa mềm.
 - Thay đổi vai trò tài khoản giữa `user, employee` và `admin` theo chính sách phân quyền của hệ thống.
 - Thay đổi trạng thái VIP giữa `"Normal"` và `"Premium"`.
 - Khóa hoặc mở khóa tài khoản thông qua trạng thái `"active"` và `"blocked"`.
 - Thực hiện Soft Delete đối với tài khoản bằng `isDeleted: true`.
 - Khôi phục tài khoản đã bị xóa mềm khi cần thiết.
 - Admin không được tự xóa hoặc vô hiệu hóa tài khoản của chính mình nếu thao tác đó có thể làm mất quyền quản trị hệ thống.
- Ràng buộc RBAC:
 - `user`: sử dụng các chức năng dành cho khách hàng.

- employee: thực hiện các chức năng vận hành được phân công như xử lý đơn hàng và hỗ trợ khách hàng.
- admin: có toàn quyền quản trị hệ thống.
- Quyền truy cập: Admin.

CHƯƠNG 4: YÊU CẦU GIAO DIỆN VÀ TÍCH HỢP (INTERFACE REQUIREMENTS)

4.1. Giao diện Người dùng (User Interface Specification)

- **Phong cách thiết kế:** Giao diện TechVie được thiết kế theo phong cách hiện đại, tối giản, sử dụng các thành phần Glassmorphism kết hợp hiệu ứng Neon/Cyber phù hợp với nhận diện thương hiệu công nghệ.
- **Responsive Design:** Giao diện phải tự động thích ứng với các kích thước màn hình phổ biến trên điện thoại, máy tính bảng và máy tính để bàn. Nội dung không được tràn khỏi màn hình, các thành phần điều hướng, biểu mẫu, bảng dữ liệu và thẻ sản phẩm phải duy trì khả năng sử dụng ở các kích thước màn hình được hỗ trợ.
- **Điều hướng:** Header, menu, Search Side Panel, Cart Side Panel và các thành phần điều hướng phải được hiển thị nhất quán giữa các trang.
- **Phản hồi thao tác:** Các thao tác như đăng nhập, thêm sản phẩm vào giỏ hàng, đặt hàng, gửi đánh giá và thao tác quản trị phải hiển thị thông báo thành công hoặc thất bại rõ ràng cho người dùng.
- **Animation:** Hệ thống có thể sử dụng các hiệu ứng chuyển động như chuyển trang, mở/đóng Side Panel, hover sản phẩm và Toast Notification nhằm cải thiện trải nghiệm người dùng nhưng không được ảnh hưởng đáng kể đến khả năng thao tác.
- **Biểu mẫu:** Các trường nhập liệu phải có nhãn hoặc placeholder rõ ràng và hiển thị thông báo khi dữ liệu không hợp lệ hoặc thiếu thông tin bắt buộc.
- **Trạng thái giao diện:** Hệ thống phải có giao diện phù hợp cho các trạng thái Loading, Empty Data, Success và Error.

4.2. Danh mục API Endpoints Chi tiết

4.2.1. Auth

Method	Endpoint Path	Quyền truy cập	Mô tả chức năng
POST	/api/auth/register	Public	Đăng ký tài khoản mới
POST	/api/auth/login	Public	Đăng nhập tài khoản
GET	/api/auth/google	Public	Khởi tạo luồng Google OAuth
GET	/api/auth/profile	Logged In	Lấy thông tin hồ sơ tài khoản hiện tại
POST	/api/auth/forgot-password	Public	Gửi email chứa link đổi mật khẩu
POST	/api/auth/reset-password/:token	Public	Đặt lại mật khẩu mới bằng Token
GET	/api/auth/google/callback	Public	Xử lý callback Google OAuth
PUT	/api/auth/profile	Logged In	Cập nhật hồ sơ cá nhân
POST	/api/auth/change-password	Logged In	Đổi mật khẩu
POST	/api/auth/send-verification-email	Logged In	Gửi email xác thực
GET	/api/auth/verify-email	Public	Xác thực email bằng token
GET	/api/auth/my-devices	Logged In	Xem thiết bị đã mua & bảo hành

4.2.2. Product

Method	Endpoint Path	Quyền truy cập	Mô tả chức năng
GET	/api/products	Public	Lấy danh sách sản phẩm & lọc
POST	/api/products	Admin	Thêm sản phẩm mới (Tải ảnh Cloudinary)
PUT	/api/products/:id	Admin	Cập nhật thông tin sản phẩm

DELETE	/api/products/:id	Admin	Xóa mềm sản phẩm
PATCH	/api/products/:id/restore	Admin	Khôi phục sản phẩm đã bị xóa

4.2.3. Category

Method	Endpoint Path	Quyền truy cập	Mô tả chức năng
GET	/api/categories	Public	Lấy danh sách danh mục
POST	/api/categories	Admin	Thêm danh mục mới
PUT	/api/categories/:id	Admin	Cập nhật danh mục
DELETE	/api/categories/:id	Admin	Xóa mềm danh mục
PATCH	/api/categories/:id/restore	Admin	Khôi phục danh mục
PATCH	/api/categories/:id/toggle	Admin	Bật/Tắt danh mục
DELETE	/api/categories/:id/permanent	Admin	Xóa vĩnh viễn danh mục

4.2.4. Order

Method	Endpoint Path	Quyền truy cập	Mô tả chức năng
POST	/api/checkout	Public	Tạo đơn đặt hàng mới
GET	/api/orders/user	Logged In	Xem lịch sử đơn hàng cá nhân
GET	/api/orders	Admin / Employee (theo quyền)	Xem danh sách đơn hàng theo phạm vi quyền
POST	/api/orders/:id/status	Admin / Employee (theo quyền)	Cập nhật trạng thái xử lý đơn hàng theo quyền
POST	/api/checkout/payment/sepay-ipn	Public (Webhook)	Webhook đối soát thanh toán ngân hàng

POST	/api/orders/:id/payment-status	Admin / Employee (theo quyền)	Cập nhật trạng thái thanh toán theo quyền
POST	/api/checkout/payment/sepay-ipn/simulate/:orderId	Test/Developer	Giả lập SePay

4.2.5. Review

Method	Endpoint Path	Quyền truy cập	Mô tả chức năng
GET	/api/reviews/:productId	Public	Lấy danh sách đánh giá sản phẩm
POST	/api/reviews/:productId	Logged In (Buyer)	Gửi đánh giá cho sản phẩm đã mua
POST	/api/reviews/admin/:reviewId/reply	Admin	Trả lời đánh giá của người dùng
PATCH	/api/reviews/:reviewId/toggle-hide	Admin	Ẩn/Hiện đánh giá

4.2.6. User

Method	Endpoint Path	Quyền truy cập	Mô tả chức năng
GET	/api/users	Admin	Quản lý danh sách thành viên hệ thống
PUT	/api/users/:id/role	Admin	Thay đổi vai trò User / Employee / Admin
PUT	/api/users/:id/status	Admin	Khóa / Mở khóa tài khoản

4.2.7. Contact

Method	Endpoint Path	Quyền truy cập	Mô tả chức năng
--------	---------------	----------------	-----------------

POST	/api/contacts	Public	Gửi ý kiến liên hệ
POST	/api/contacts/:id/reply	Admin / Employee (theo quyền)	Trả lời liên hệ qua SMTP Email
GET	/api/contacts	Admin / Employee (theo quyền)	Xem danh sách thư liên hệ theo phạm vi quyền
DELETE	/api/contacts/:id	Admin	Xóa thư liên hệ

4.2.8. Voucher

Method	Endpoint Path	Quyền truy cập	Mô tả chức năng
GET	/api/vouchers	Public	Lấy danh sách mã giảm giá
POST	/api/vouchers	Admin	Tạo mã giảm giá mới
PUT	/api/vouchers/:id/toggle	Admin	Bật/Tắt Voucher
DELETE	/api/vouchers/:id	Admin	Xóa Voucher

4.2.9. Search

Method	Endpoint Path	Quyền truy cập	Mô tả chức năng
GET	/api/search/popular	Public	Top 5 từ khóa phổ biến
GET	/api/search/history	Public / Optional JWT	Lịch sử tìm kiếm

4.3. Tích hợp Dịch vụ Bên thứ 3 (External Interfaces)

- **Cloudinary API – Lưu trữ hình ảnh:** Hệ thống sử dụng Cloudinary để lưu trữ hình ảnh sản phẩm do Admin tải lên. Backend tiếp nhận tệp hình ảnh thông qua Multer, tải ảnh lên Cloudinary và lưu URL ảnh trả về vào

dữ liệu sản phẩm. Khi hình ảnh sản phẩm được thay đổi, hệ thống có thể xóa tài nguyên ảnh cũ để hạn chế dữ liệu không còn sử dụng.

- **Google OAuth 2.0 – Xác thực tài khoản Google:** Hệ thống tích hợp Google OAuth 2.0 để hỗ trợ đăng nhập và đăng ký tài khoản bằng Google. Người dùng được điều hướng tới Google Consent Screen; sau khi cấp quyền, Google trả Authorization Code về Callback của Backend. Backend xác minh quá trình OAuth, lấy thông tin tài khoản Google và tạo hoặc liên kết tài khoản TechVie tương ứng. Sau khi xác thực thành công, hệ thống phát hành JWT Token của TechVie cho phiên đăng nhập.
- **Nodemailer SMTP – Dịch vụ Email:** Backend sử dụng Nodemailer kết nối với máy chủ SMTP để gửi email phục vụ các chức năng của hệ thống, bao gồm xác thực địa chỉ email, khôi phục mật khẩu và phản hồi yêu cầu liên hệ của khách hàng.
- **SePay IPN – Đối soát Chuyển khoản Ngân hàng:** Khi khách hàng lựa chọn phương thức bank_transfer, hệ thống cung cấp thông tin thanh toán và mã đơn hàng phục vụ đối soát. SePay gửi thông báo giao dịch tới endpoint POST /api/checkout/payment/sepay-ipn. Backend xác định đơn hàng, đối chiếu số tiền và cập nhật payment_status: "paid" khi giao dịch hợp lệ.
- **MoMo – Thanh toán Ví điện tử:** Hệ thống hỗ trợ phương thức thanh toán MoMo trong môi trường Sandbox/Demo. Thông tin giao dịch và trạng thái thanh toán được xử lý theo giao diện tích hợp do nhà cung cấp cung cấp.
- **ZaloPay – Thanh toán Ví điện tử:** Hệ thống hỗ trợ phương thức thanh toán ZaloPay trong môi trường Sandbox/Demo. Sau khi có kết quả giao dịch, trạng thái thanh toán của đơn hàng được cập nhật tương ứng.
- **VNPAY – Thanh toán Trực tuyến:** Hệ thống hỗ trợ thanh toán thông qua VNPAY trong môi trường Sandbox/Demo. Người dùng được chuyển tới giao diện thanh toán phù hợp và kết quả giao dịch được sử dụng để cập nhật trạng thái thanh toán của đơn hàng.

CHƯƠNG 5: YÊU CẦU PHI CHỨC NĂNG (NON-FUNCTIONAL REQUIREMENTS)

5.1. Hiệu năng & Khả năng Mở rộng (Performance & Scalability)

- **Thời gian phản hồi:** Trong điều kiện hoạt động bình thường, ít nhất 95% các yêu cầu đọc dữ liệu phải có thời gian phản hồi không vượt quá 200

ms, và ít nhất 95% các yêu cầu ghi dữ liệu phải có thời gian phản hồi không vượt quá 500 ms, không tính độ trễ do các dịch vụ bên thứ ba nằm ngoài phạm vi kiểm soát của hệ thống.

- **Khả năng mở rộng:** Kiến trúc hệ thống phải cho phép mở rộng tài nguyên Frontend, Backend và cơ sở dữ liệu nhằm đáp ứng sự gia tăng số lượng người dùng và dữ liệu mà không yêu cầu thay đổi lớn về kiến trúc ứng dụng.
- **Khả năng chịu tải:** Hệ thống đặt mục tiêu hỗ trợ tối thiểu 1.000 người dùng truy cập đồng thời đối với các chức năng phổ biến như xem sản phẩm và tìm kiếm mà vẫn duy trì tính ổn định và không phát sinh lỗi nghiêm trọng.

5.2. An toàn & Bảo mật Hệ thống (Security & Safety)

- **Bảo vệ mật khẩu:** Mật khẩu người dùng phải được băm (hash) bằng bcryptjs với salt round = 10 trước khi lưu vào cơ sở dữ liệu và không được lưu dưới dạng văn bản thuần (Plain Text).
- **Bảo vệ Token:** Các token dùng cho chức năng khôi phục mật khẩu và xác thực email phải có thời hạn sử dụng giới hạn. Các token nhạy cảm được băm bằng SHA-256 trước khi lưu trữ khi thiết kế chức năng yêu cầu.
- **Xác thực:** Các API yêu cầu đăng nhập phải xác thực JWT trước khi cho phép người dùng truy cập tài nguyên được bảo vệ.
- **Phân quyền:** Hệ thống phải áp dụng RBAC và chỉ cho phép người dùng thực hiện các chức năng phù hợp với vai trò được cấp (user, employee, admin). Các chức năng quản trị cấp cao chỉ dành cho Admin.
- **Trạng thái tài khoản:** Tài khoản có status: "blocked" hoặc isDeleted: true không được phép sử dụng các chức năng yêu cầu tài khoản hoạt động.
- **Kiểm tra dữ liệu đầu vào:** Backend phải kiểm tra và xác thực dữ liệu đầu vào nhằm hạn chế dữ liệu không hợp lệ, Injection, XSS và các yêu cầu truy cập trái phép.
- **Khôi phục mật khẩu:** Liên kết đặt lại mật khẩu chỉ có hiệu lực trong thời gian quy định, hiện tại là 15 phút, và không được sử dụng lại sau khi đặt lại mật khẩu thành công.
- **Bảo mật giao tiếp:** Trong môi trường triển khai Production, việc truyền dữ liệu giữa Client, Server và các dịch vụ bên thứ ba phải sử dụng kết nối HTTPS khi dịch vụ hỗ trợ.

5.3. Độ tin cậy & Khả năng Sẵn sàng (Reliability & Availability)

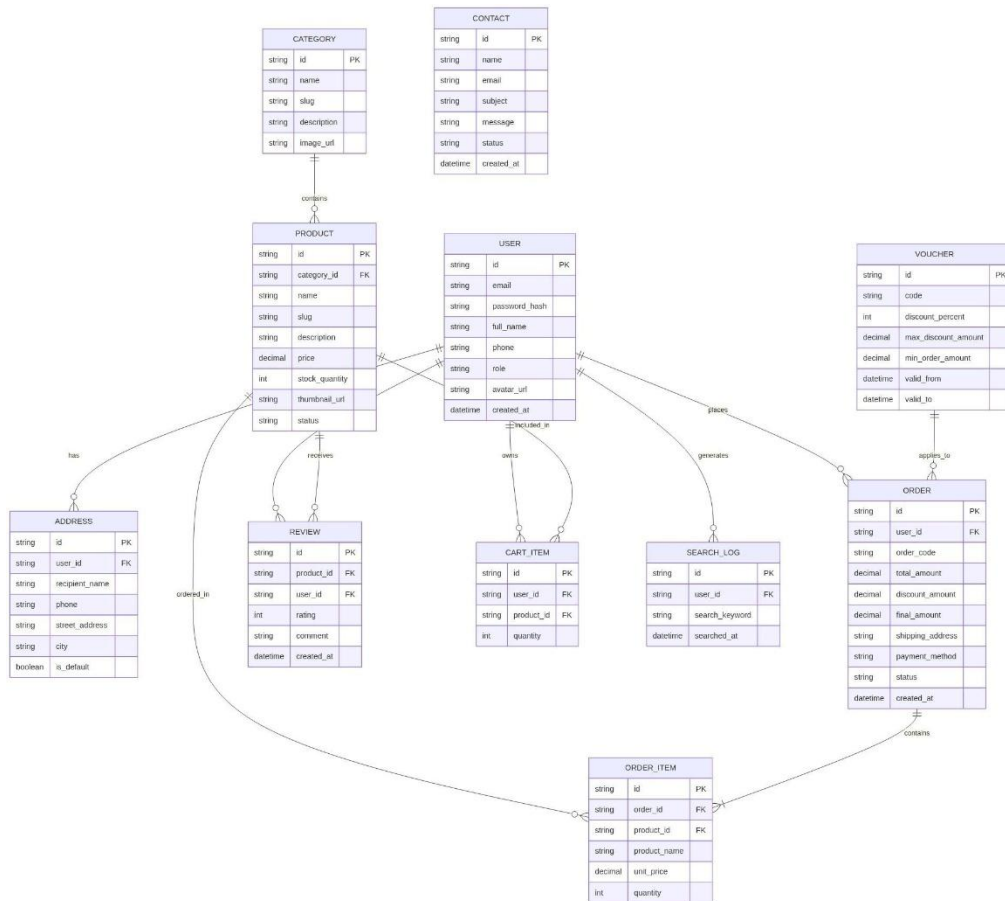
- **Tính sẵn sàng:** Trong môi trường Production, hệ thống đặt mục tiêu đạt mức sẵn sàng tối thiểu 99,9%, không tính thời gian bảo trì được lên kế hoạch trước và sự cố phát sinh hoàn toàn từ dịch vụ bên thứ ba.
- **Tính toàn vẹn dữ liệu:** Hệ thống phải đảm bảo dữ liệu đơn hàng, thanh toán, tồn kho và tài khoản không bị cập nhật ở trạng thái không nhất quán trong các quy trình nghiệp vụ chính.
- **Bảo toàn dữ liệu:** Các dữ liệu quan trọng như tài khoản, sản phẩm, đơn hàng và đánh giá phải ưu tiên sử dụng Soft Delete khi yêu cầu nghiệp vụ cần bảo lưu lịch sử.
- **Xử lý lỗi:** Khi xảy ra lỗi Backend hoặc lỗi từ dịch vụ bên thứ ba, hệ thống phải trả về thông báo phù hợp và không được tạo dữ liệu giao dịch không hoàn chỉnh hoặc không xác định được trạng thái.

5.4. Trải nghiệm Người dùng (Usability & Accessibility)

- **Phản hồi thao tác:** Hệ thống phải hiển thị trạng thái Loading và thông báo thành công hoặc thất bại phù hợp cho các thao tác có xử lý bất đồng bộ.
- **Responsive Design:** Giao diện phải thích ứng với các kích thước màn hình phổ biến trên điện thoại, máy tính bảng và máy tính để bàn mà không làm mất các chức năng chính.
- **Khả năng tương thích:** Hệ thống phải hoạt động ổn định trên các trình duyệt web hiện đại như Google Chrome, Mozilla Firefox, Microsoft Edge và Apple Safari.
- **Tính nhất quán:** Các thành phần như nút, biểu mẫu, Header, Search Panel, Cart Panel và thông báo phải có cách trình bày và hành vi nhất quán giữa các trang.
- **Tính dễ sử dụng:** Các luồng nghiệp vụ chính như tìm sản phẩm, thêm vào giỏ, Checkout, đăng nhập và quản lý tài khoản phải được thiết kế rõ ràng, hạn chế các bước không cần thiết.

CHƯƠNG 6: ĐẶC TẢ CƠ SỞ DỮ LIỆU & SƠ ĐỒ HỆ THỐNG (DATABASE & SYSTEM MODELS)

6.1. Sơ đồ Thực thể Liên kết (ERD Diagram)



Hình 5. Sơ đồ Thực thể Liên kết (ERD) của hệ thống TechVie

6.2. Từ điển Dữ liệu Chi tiết (Data Dictionary / Schemas)

6.2.1. Collection users (Quản lý Tài khoản)

Tên trường	Kiểu dữ liệu	Bắt buộc	Mặc định	Mô tả
_id	ObjectId	Có	Auto	Khóa chính
username	String	Có	-	Tên hiển thị người dùng
email	String	Có	-	Email đăng nhập (Unique, Lowercase)
password	String	Có	-	Mật khẩu đã được băm (hash) bằng bcryptjs
phone	String	Không	-	Số điện thoại liên hệ

role	String	Có	"user"	Vai trò hệ thống ("user", "employee", "admin")
vipStatus	String	Có	"Normal"	Cấp độ thành viên ("Normal" / "Premium")
status	String	Có	"active"	Trạng thái tài khoản ("active" / "blocked")
auth_provider	String	Có	"credentials"	Nguồn xác thực ("credentials" / "google")
isEmailVerified	Boolean	Có	false	Xác nhận email đã xác thực
isDeleted	Boolean	Có	false	Cờ xóa mềm (Soft Delete)
createdAt	Date	Có	Date.now	Thời điểm khởi tạo tài khoản
address	String	Không	-	Địa chỉ người dùng
google_id	String	Không	-	ID tài khoản Google đã liên kết
avatar	String	Không	-	URL ảnh đại diện
resetPasswordToken	String	Không	-	Bản băm SHA-256 của token đặt lại mật khẩu
resetPasswordExpire	Date	Không	-	Thời điểm hết hạn token đặt lại mật khẩu
emailVerificationToken	String	Không	-	Bản băm token xác thực email
emailVerificationExpire	Date	Không	-	Thời điểm hết hạn token xác thực email

6.2.2. Collection products (Danh mục Sản phẩm)

Tên trường	Kiểu dữ liệu	Bắt buộc	Mặc định	Mô tả
_id	String	Có	-	Mã sản phẩm (Slugified ID)
name	String	Có	-	Tên thương phẩm
category	String	Có	-	Tên danh mục (Foreign Key ref Category)
specs	Object	Không	{}	Thông số kỹ thuật của sản phẩm
colors	Array[String]	Không	[]	Danh sách màu sắc sản phẩm
price	Number	Có	-	Giá niêm yết (VND)
originalPrice	Number	Không	-	Giá trước giảm
stock	Number	Có	0	Số lượng tồn kho khả dụng
image	String	Không	-	URL hình ảnh sản phẩm trên Cloudinary
description	String	Không	-	Mô tả chi tiết sản phẩm
created_at	Date	Có	Date.now	Thời điểm tạo sản phẩm
status	String	Có	"AVAILABLE"	Trạng thái kinh doanh ("AVAILABLE", "OUT_OF_STOCK", "DISCONTINUED")
badge	String	Có	"NORMAL"	Huy hiệu nổi bật ("PREMIUM", "TRENDY", "FLAGSHIP", "LIMITED", "NORMAL")
averageRating	Number	Có	0	Điểm đánh giá trung bình (1.0 - 5.0)

reviewCount	Number	Có	0	Tổng số lượt đánh giá
isDeleted	Boolean	Có	false	Cờ xóa mềm

6.2.3. Collection orders (Đơn hàng & Giao dịch)

Tên trường	Kiểu dữ liệu	Bắt buộc	Mặc định	Mô tả
_id	ObjectId	Có	Auto	Mã định danh đơn hàng
user_id	ObjectId (Ref)	Không	-	ID người dùng (Nếu đã đăng nhập)
full_name	String	Có	-	Tên người nhận hàng
email	String	Có	-	Email người đặt
phone	String	Có	-	Số điện thoại nhận hàng
address	String	Có	-	Địa chỉ chi tiết điểm giao hàng
notes	String	Không	-	Ghi chú giao hàng
payment_method	String	Có	-	cod / card_online / bank_transfer / momo / zalopay / vnpay
payment_status	String	Có	"pending"	pending / paid / failed / cancelled
delivery_method	String	Có	-	express / standard
status_type	String	Có	"processing"	processing / shipping / success / cancelled
items	Array [Schema]	Có	[]	Danh sách các sản phẩm mua trong đơn
createdAt	Date	Có	Date.now	Thời điểm đặt hàng
subtotal	Number	Có	0	Tổng giá trị hàng hóa trước phí và giảm giá
deliveryFee	Number	Có	0	Phí vận chuyển

discountAmount	Number	Có	0	Số tiền được giảm
transaction_id	String	Không	-	Mã giao dịch từ công thanh toán
voucher_code	String	Không	-	Mã Voucher đã áp dụng
final_total	Number	Có	0	Tổng tiền cuối cùng của đơn hàng
paid_at	Date	Không	-	Thời điểm xác nhận thanh toán

6.2.4. Collection reviews (Đánh giá Sản phẩm)

Tên trường	Kiểu dữ liệu	Bắt buộc	Mặc định	Mô tả
_id	ObjectId	Có	Auto	Khóa chính
product_id	String (Ref)	Có	-	Mã sản phẩm được đánh giá
user_id	ObjectId (Ref)	Có	-	ID người dùng viết đánh giá
username	String	Có	-	Tên hiển thị người đánh giá
order_id	ObjectId (Ref)	Có	-	Mã đơn hàng xác minh đã mua
title	String	Không	-	Tiêu đề đánh giá
rating	Number	Có	-	Điểm số đánh giá (1 - 5)
comment	String	Có	-	Nội dung bình luận
verified_purchase	Boolean	Có	true	Xác nhận đã mua hàng thực tế
isHidden	Boolean	Có	false	Trạng thái ẩn vi phạm
reply	Object	Không	-	Phản hồi từ Admin (comment, replied_at, admin_username)

isDeleted	Boolean	Có	false	Cờ xóa mềm
-----------	---------	----	-------	------------

6.2.5. Collection categories

Tên trường	Kiểu dữ liệu	Bắt buộc	Mặc định	Mô tả
_id	ObjectId	Có	Auto	Khóa chính của danh mục
name	String	Có	-	Tên danh mục sản phẩm, không được để trống và phải duy nhất
isDeleted	Boolean	Có	false	Trạng thái xóa mềm/vô hiệu hóa danh mục
created_at	Date	Có	Date.now	Thời điểm tạo danh mục

6.2.6. Collection vouchers

Tên trường	Kiểu dữ liệu	Bắt buộc	Mặc định	Mô tả
_id	ObjectId	Có	Auto	Khóa chính của Voucher
code	String	Có	-	Mã Voucher duy nhất, chuẩn hóa thành chữ in hoa
discount	Number	Có	-	Tỷ lệ giảm giá của Voucher
description	String	Không	""	Mô tả nội dung chương trình khuyến mãi
usedCount	Number	Có	0	Số lượt Voucher đã được sử dụng, phục vụ thống kê
minOrderVal	Number	Có	0	Giá trị đơn hàng tối thiểu để được áp dụng Voucher

isActive	Boolean	Có	true	Trạng thái kích hoạt của Voucher
created_at	Date	Có	Date.now	Thời điểm tạo Voucher

6.2.7. Collection contacts

Tên trường	Kiểu dữ liệu	Bắt buộc	Mặc định	Mô tả
_id	ObjectId	Có	Auto	Khóa chính của thư liên hệ
name	String	Có	-	Họ tên người gửi liên hệ
email	String	Có	-	Email của người gửi, dùng để nhận phản hồi
subject	String	Không	-	Chủ đề của yêu cầu liên hệ
message	String	Không	-	Nội dung yêu cầu, góp ý hoặc đăng ký Newsletter
created_at	Date	Có	Date.now	Thời điểm gửi yêu cầu liên hệ

6.2.8. Collection searchlogs

Tên trường	Kiểu dữ liệu	Bắt buộc	Mặc định	Mô tả
_id	ObjectId	Có	Auto	Khóa chính của bản ghi tìm kiếm
query	String	Có	-	Từ khóa mà người dùng thực hiện tìm kiếm
userId	String / Null	Không	null	ID người dùng nếu request có JWT hợp lệ; để null đối với Guest

ip	String	Không	-	Địa chỉ IP của request, dùng nhận diện lịch sử của Guest
created_at	Date	Có	Date.now	Thời điểm thực hiện tìm kiếm

6.3. Ma trận Phân quyền Hệ thống (RBAC Matrix)

Chức năng / Quyền hạn	Guest	User	Employee	Admin
Xem danh sách & chi tiết sản phẩm	✓	✓	✓	✓
Tìm kiếm & Lọc sản phẩm	✓	✓	✓	✓
Thêm hàng vào giỏ & Đặt hàng (Checkout)	✓	✓	✗	✗
Đăng ký tài khoản	✓	✗	✗	✗
Đăng nhập (Local & Google)	✓	✓	✓	✓
Quên & Đặt lại mật khẩu	✓	✓*	✓*	✓*
Xác thực Email	✗	✓	✓	✓
Quản lý Hồ sơ cá nhân & Đổi mật khẩu	✗	✓	✓	✓
Xem Lịch sử Đơn hàng cá nhân	✗	✓	✗	✗
Tra cứu Thiết bị đã mua & Bảo hành	✗	✓	✗	✗
Viết Đánh giá sản phẩm đã mua	✗	✓*	✗	✗
Gửi Thư liên hệ & Đăng ký Newsletter	✓	✓	✗	✗
Xem & Xử lý Hòm thư Liên hệ	✗	✗	△	✓
Quản lý Sản phẩm (CRUD, Cloudinary)	✗	✗	✗	✓
Quản lý Danh mục & Voucher	✗	✗	✗	✓

Xem & Cập nhật Trạng thái mọi Đơn hàng	X	X	△	✓
Cập nhật Trạng thái Thanh toán	X	X	△	✓
Phản hồi/Ấn/Xóa/Khôi phục Đánh giá	X	X	X	✓
Quản lý Thành viên (Khóa/Mở khóa, Phân quyền)	X	X	X	✓
Xem Dashboard Doanh thu & Báo cáo	X	X	△	✓
Ghi chú: ✓: Được phép thực hiện chức năng. X: Không được phép thực hiện chức năng. △: Chỉ được thực hiện trong phạm vi quyền hoặc dữ liệu được phân công. ✓*: Chức năng có điều kiện. Đặt lại mật khẩu chỉ áp dụng đối với tài khoản sử dụng phương thức xác thực bằng thông tin đăng nhập; đánh giá sản phẩm chỉ áp dụng khi khách hàng đáp ứng điều kiện Verified Purchase.				

CHƯƠNG 7: BẢNG KIỂM THỬ VÀ KỸ THUẬT THIẾT KẾ TEST (SOFTWARE TESTING ARTIFACTS)

7.1. Ma trận Truy xuất Yêu cầu (Requirements Traceability Matrix - RTM)

Mã Yêu Cầu (Req ID)	Tên Chức Năng	Kỹ Thuật Kiểm Thử Đề Xuất	Mã Kịch Bản Test (Test Scenario ID)
FR-AUTH-01	Đăng ký Tài khoản	Phân vùng tương đương (EP), Giá trị biên (BVA)	TS_AUTH_REG_01 → TS_AUTH_REG_04
FR-AUTH-02	Đăng nhập Hệ thống	Bảng quyết định, Kiểm thử An ninh (Security)	TS_AUTH_LGN_01 → TS_AUTH_LGN_04
FR-AUTH-03	Đăng nhập bằng Google OAuth 2.0	Kiểm thử Tích hợp, Security Testing	TS_AUTH_GOOGLE_01 → TS_AUTH_GOOGLE_04

FR-AUTH-04	Quên & Đặt lại Mật khẩu	EP, BVA, Security Testing	TS_AUTH_RESET_01 → TS_AUTH_RESET_06
FR-AUTH-05	Xác thực Email	Kiểm thử Tích hợp, Giá trị biên thời gian Token	TS_AUTH_VERIFY_01 → TS_AUTH_VERIFY_05
FR-AUTH-06	Quản lý Hồ sơ & Đổi Mật khẩu	Functional Testing, Security Testing	TS_AUTH_PROFILE_01 → TS_AUTH_PROFILE_05
FR-AUTH-07	Tra cứu Thiết bị đã mua & Bảo hành	Functional Testing, Authorization Testing	TS_AUTH_DEVICE_01 → TS_AUTH_DEVICE_04
FR-PROD-01	Truy vấn Danh sách, Lọc & Sắp xếp Sản phẩm	EP, Combinatorial Testing	TS_PRD_SRC_01 → TS_PRD_SRC_06
FR-PROD-02	Thêm mới Sản phẩm	EP, BVA, Cloudinary Integration Testing	TS_PRD_CREATE_01 → TS_PRD_CREATE_05
FR-PROD-03	Cập nhật, Xóa mềm & Khôi phục Sản phẩm	Functional Testing, State Testing, Cloudinary Upload	TS_PRD_MGMT_01 → TS_PRD_MGMT_06
FR-CAT-01	Truy vấn Danh sách Danh mục	Functional Testing	TS_CAT_GET_01 → TS_CAT_GET_02
FR-CAT-02	Tạo & Cập nhật Danh mục	EP, Duplicate Validation	TS_CAT_CU_01 → TS_CAT_CU_04
FR-CAT-03	Vô hiệu hóa, Khôi phục & Xóa Danh mục	State Transition Testing, RBAC Testing	TS_CAT_STATE_01 → TS_CAT_STATE_05
FR-SRCH-01	Tìm kiếm Sản phẩm Thời gian Thực	EP, Functional Testing	TS_SRC_REALTIME_01 → TS_SRC_REALTIME_04
FR-SRCH-02	Ghi nhận Nhật ký Tìm kiếm	Integration Testing, Data Validation	TS_SRC_LOG_01 → TS_SRC_LOG_03
FR-SRCH-03	Từ khóa Phổ biến & Lịch sử Tìm kiếm	Functional Testing, Data Validation	TS_SRC_HISTORY_01 → TS_SRC_HISTORY_04

FR-CART-01	Quản lý Giỏ hàng	BVA, Functional Testing	TS_CRT_01 → TS_CRT_04
FR-VOCH-01	Áp dụng Mã Giảm giá	Decision Table Testing, BVA	TS_VOU_01 → TS_VOU_05
FR-VOCH-02	Quản lý Mã Giảm giá	Functional Testing, RBAC Testing	TS_VOU_ADM_01 → TS_VOU_ADM_05
FR-ORD-01	Quy trình Đặt hàng (Checkout)	EP, BVA, Integration Testing	TS_CHK_01 → TS_CHK_08
FR-ORD-02	Tích hợp Thanh toán & SePay IPN Webhook	Integration Testing, Mock Webhook	TS_PAY_QR_01 → TS_PAY_QR_03
FR-ORD-03	Quản lý Vòng đời Đơn hàng	State Transition Testing	TS_ORD_ST_01 → TS_ORD_ST_05
FR-REV-01	Gửi Đánh giá Verified Purchase	Integration Testing, Compound Index Validation	TS_REV_01 → TS_REV_04
FR-REV-02	Tính Điểm Đánh giá Trung bình	Data Validation, Functional Testing	TS_REV_RATE_01 → TS_REV_RATE_04
FR-REV-03	Quản trị Đánh giá	Functional Testing, RBAC Testing	TS_REV_ADM_01 → TS_REV_ADM_05
FR-CNT-01	Gửi Thư Liên hệ	EP, Input Validation	TS_CNT_SEND_01 → TS_CNT_SEND_04
FR-CNT-02	Quản lý & Trả lời Thư Liên hệ	Integration Testing, RBAC Testing	TS_CNT_ADM_01 → TS_CNT_ADM_05
FR-CNT-03	Đăng ký Nhận Bản tin Newsletter	Functional Testing, Input Validation	TS_CNT_NEWS_01 → TS_CNT_NEWS_03
FR-ADM-01	Bảng Điều khiển Tổng quan	Data Validation, Functional Testing	TS_ADM_DASH_01 → TS_ADM_DASH_05
FR-ADM-02	Quản lý Thành viên & Phân quyền	RBAC Testing, Functional Testing	TS_ADM_USR_01 → TS_ADM_USR_05

7.2. Bảng Chuyển Trạng Thái Đơn Hàng (State Transition Table)

Trạng thái hiện tại	Sự kiện / Hành động (Input Trigger)	Trạng thái tiếp theo (status_type)	Trạng thái thanh toán (payment_status)	Kết quả mong đợi
Khởi tạo	Khách xác nhận đặt hàng bằng COD	processing	pending	Đơn hàng được tạo thành công, lưu thông tin giao nhận và cập nhật tồn kho
Khởi tạo	Khách xác nhận đặt hàng bằng Bank Transfer / SePay	processing	pending	Đơn hàng được tạo thành công và hệ thống hiển thị thông tin/QR thanh toán
processing	SePay gửi IPN hợp lệ và số tiền thanh toán khớp với đơn hàng	processing	paid	Hệ thống xác nhận thanh toán thành công, lưu paid_at và transaction_id
processing	Admin hoặc Employee được cấp quyền xác nhận đơn đã được chuẩn bị và chuyển giao cho đơn vị vận chuyển	shipping	Giữ nguyên	Hệ thống cập nhật status_type = "shipping"
shipping	Đơn hàng được giao thành công; đối với COD, thanh toán được xác nhận khi nhận hàng	success	paid	Đơn hàng hoàn tất, được ghi nhận trong lịch sử mua hàng và đủ điều kiện phục vụ Review/Bảo hành
processing	Admin hủy đơn hàng trước khi chuyển sang giao hàng	cancelled	cancelled nếu chưa thanh toán	Đơn hàng bị hủy và số lượng sản phẩm đã trừ được hoàn trả về tồn kho
processing / shipping	Yêu cầu cập nhật sang trạng thái không hợp lệ hoặc không đúng quyền	Giữ nguyên	Giữ nguyên	Hệ thống từ chối thao tác và trả về thông báo lỗi phù hợp
Ghi chú: status_type của đơn hàng gồm: processing, shipping, success, cancelled.				

- payment_status gồm: pending, paid, failed, cancelled.
- Employee chỉ được cập nhật đơn hàng trong phạm vi quyền được phân công theo RBAC.
- Đối với đơn hàng đã thanh toán trực tuyến nhưng cần hủy, việc hoàn tiền phụ thuộc vào quy trình của công ty thanh toán và không được tự động giả định trong bảng chuyển trạng thái này.

7.3. Bảng Quyết Định Kiểm Thử Mã Giảm Giá (Decision Table - Voucher)

Điều kiện / Hành động	Rule 1	Rule 2	Rule 3	Rule 4
Điều kiện				
Mã Voucher có tồn tại trong hệ thống?	K	C	C	C
Voucher có isActive: true?	-	K	C	C
subtotal >= minOrderVal?	-	-	K	C
Hành động				
Chấp nhận áp dụng Voucher	K	K	K	C
Tính discountAmount = subtotal × discount	K	K	K	C
Tính lại finalTotal = subtotal + deliveryFee - discountAmount	K	K	K	C
Hiển thị thông báo Voucher không tồn tại	C	K	K	K
Hiển thị thông báo Voucher đang tạm dừng	K	C	K	K
Hiển thị thông báo chưa đạt giá trị đơn hàng tối thiểu	K	K	C	K
Hiển thị thông báo áp dụng Voucher thành công	K	K	K	C
Ghi chú: C = Có/Đúng, K = Không/Sai, - = Không xét. Ý nghĩa 4 Rule: • Rule 1: Mã không tồn tại → từ chối. • Rule 2: Mã có tồn tại nhưng isActive = false → từ chối. • Rule 3: Voucher hoạt động nhưng đơn hàng chưa đạt minOrderVal → từ chối.				

- Rule 4: Tất cả điều kiện hợp lệ → áp dụng giảm giá.

7.4. Môi Trường & Công Cụ Kiểm Thử Đề Xuất (Test Environment Setup)

7.4.1. Kiểm thử API & Tích hợp (API & Integration Testing):

Sử dụng Postman làm công cụ chính để kiểm thử các RESTful API của hệ thống. Có thể sử dụng Bruno hoặc Insomnia làm công cụ hỗ trợ khi cần thiết. Phạm vi kiểm thử bao gồm các nhóm API như /api/auth, /api/products, /api/categories, /api/search, /api/checkout, /api/orders, /api/reviews, /api/users, /api/contacts và /api/vouchers.

Các nội dung kiểm thử bao gồm:

- Kiểm tra HTTP Method, Status Code và Response Body.
- Kiểm tra dữ liệu đầu vào hợp lệ/không hợp lệ.
- Kiểm tra JWT Authentication và RBAC.
- Kiểm tra các API Public, Logged In, Employee và Admin.
- Kiểm thử tích hợp Google OAuth, Cloudinary, SMTP Email và thanh toán.
- Kiểm thử SePay IPN thông qua Webhook và endpoint giả lập trong môi trường Test.

7.4.2. Kiểm thử Giao diện & End-to-End (UI & E2E Testing):

Có thể sử dụng Playwright, Cypress hoặc Selenium WebDriver để tự động hóa các luồng nghiệp vụ chính trên giao diện.

Các luồng E2E ưu tiên gồm:

- Đăng ký → Đăng nhập → Xác thực tài khoản.
- Tìm kiếm sản phẩm → Thêm vào giỏ hàng → Checkout.
- Áp dụng Voucher → Chọn phương thức thanh toán → Tạo đơn hàng.
- Theo dõi đơn hàng → Giao hàng thành công → Gửi Review.
- Admin đăng nhập → Quản lý sản phẩm → Đơn hàng → Người dùng.
- Employee đăng nhập → Xử lý các chức năng vận hành được phân quyền.

7.4.3. Kiểm thử Hiệu năng (Performance & Load Testing):

Sử dụng Apache JMeter hoặc k6 để kiểm thử tải đối với các API có tần suất truy cập cao như danh sách sản phẩm, tìm kiếm sản phẩm và các API đọc dữ liệu.

7.4.4. Kiểm thử Bảo mật (Security Testing):

Sử dụng OWASP ZAP kết hợp với kiểm thử thủ công để kiểm tra các vấn đề bảo mật chính, bao gồm:

- JWT Authentication.
- Kiểm soát phân quyền RBAC.
- Truy cập trái phép vào API Admin/Employee.
- XSS.
- Injection.
- Broken Object Level Authorization.
- Dữ liệu đầu vào không hợp lệ.
- Tài khoản blocked hoặc isDeleted cố gắng truy cập hệ thống.

7.4.5. Kiểm thử các Dịch vụ Bên thứ ba (External Service Testing)

Các dịch vụ thanh toán như SePay, MoMo, ZaloPay và VNPay được kiểm thử trong môi trường Sandbox/Demo khi có hỗ trợ. Không sử dụng giao dịch tài chính thực trong quá trình kiểm thử chức năng thông thường.

Các tích hợp khác gồm:

- Cloudinary: kiểm thử Upload/Update hình ảnh.
- Google OAuth 2.0: kiểm thử đăng nhập và liên kết tài khoản.
- Nodemailer SMTP: kiểm thử Email Verification, Reset Password và Reply Contact.
- SePay IPN: kiểm thử đối soát giao dịch và cập nhật payment_status.

7.4.6. Chức năng hỗ trợ Demo/Test:

Chức năng Quick Switch Account, nếu được sử dụng, chỉ phục vụ việc chuyển nhanh giữa các tài khoản mẫu nhằm kiểm thử giao diện và RBAC.

TỔNG KẾT TÀI LIỆU

Tài liệu SRS này quy định đầy đủ các tiêu chuẩn kỹ thuật, cấu trúc cơ sở dữ liệu, các sơ đồ hệ thống và quy trình nghiệp vụ của Hệ thống Website Thương mại Điện tử TechVie. Đội ngũ phát triển và kiểm thử có trách nhiệm tuân thủ

nghiêm ngặt các quy định trong tài liệu này trong suốt quá trình vận hành và bảo trì sản phẩm.